

GHOSTWIRE

Threat intelligence, told as narrative.

#ISSUE 001

EARLY 2026

Sandworm

The Most Destructive Cyberattack in History Didn't Come From Nowhere.

// INTELLIGENCE FILE – GW-001-SWM //

SUBJECT:	Sandworm Team (APT44)
ATTRIBUTION:	GRU Unit 74455 (GTsST)
PRIMARY TARGET:	Ukraine – Critical Infrastructure
ACTIVITY WINDOW:	2009 – Present
OFFICERS INDICTED:	6 (October 2020)
THREAT LEVEL:	CRITICAL

\$10B

2009

6 GRU

APT44

On June 27 2017, a weapon disguised as ransomware detonated across Ukrainian networks and escaped into the global economy. \$10 billion in damage. The most destructive cyberattack in recorded history. This is the story of the unit that built it – and everything they did before, during, and after.

On June 27, 2017, a weapon disguised as ransomware detonated across Ukrainian networks and escaped into the global economy. Within hours, the world's largest shipping company couldn't move cargo. A pharmaceutical giant couldn't manufacture drugs. A logistics conglomerate's European operations went dark. The ransom demands were fake. The payment instructions were theater. There was never a decryption key, because recovery was never the point.

The point was destruction.

The weapon was NotPetya – formally tracked as Win32/Diskcoder.C – and it caused an estimated \$10 billion in damage, making it the most destructive cyberattack in recorded history. By a significant margin. But NotPetya is not the story. NotPetya is the headline. The story is the organisation that built it, deployed it, and has been operating against Ukraine and the broader world for over a decade before and since.

The story is Sandworm.

SECTION 01

Executive Summary

Sandworm – formally designated **APT44** by Mandiant in April 2024 – is a Russian state-sponsored threat group attributed to **GRU Unit 74455**, the Main Centre for Special Technologies (GTsST), subordinated to the GRU's Information Operations Troops. Active since at least 2009. In October 2020, a US federal grand jury indicted six of their officers by name.

What makes Sandworm different from every other Russian state-sponsored threat actor is **scope**. Most groups specialise – APT28 collects intelligence, COZY BEAR runs espionage. Sandworm does all of it. Espionage. Destructive attack. Information operations. Simultaneously. Integrated. In service of whatever Russian national interest needs serving at the time.

What They've Done

DECEMBER 2015	First Power Grid Attack First confirmed cyberattack to cause a real-world power outage. 230,000 Ukrainians without power in winter, using BlackEnergy malware and remote commands to substation breakers.
DECEMBER 2016	Second Grid Attack + TeleBots Campaign Industroyer deployed against Kyiv's power infrastructure – purpose-built ICS malware speaking industrial protocols natively. Simultaneously: KillDisk wiper attacks against Ukrainian financial institutions begin.
JUNE 27, 2017	NotPetya \$10 billion. Maersk. Merck. FedEx. Saint-Gobain. Reckitt Benckiser. Mondelez. The most destructive cyberattack in history, deployed against Ukraine and escaped globally via VPN connections.

2018 Olympic Destroyer + OPCW Pyeongchang Winter Olympics opening ceremony disrupted – payback for Russia's doping ban, wrapped in false attribution pointing at North Korea and China. Also: targeting of the OPCW's Novichok investigation.

2022 – PRESENT Wartime Cyber Campaign Six-phase sustained campaign: Industroyer.V2 against high-voltage substations, repeated CADDYWIPER deployments, battlefield reconnaissance, drone manufacturer phishing, Infamous Chisel Android malware targeting Ukrainian military devices.

Thomas Bossert, then Homeland Security Advisor to the US President, called NotPetya "the equivalent of using a nuclear bomb to achieve a small tactical victory. That's a degree of recklessness we can't tolerate on the world stage." The world tolerated it. Sandworm kept going. Six GRU officers were indicted in 2020. None will face trial. The operational tempo didn't change.

// Key Judgments

APT44 is Russia's preeminent cyber sabotage unit – conducting espionage, destructive attack, and influence operations as an integrated whole.

NotPetya was not an anomaly. It was the culmination of years of deliberate capability building, and Sandworm has continued to evolve since.

The global threat is real and underappreciated. OT attack capability developed against Ukraine is not Ukraine-specific. The mandate is global.

SECTION 02

Attribution & Identity

"Sandworm" is just the name Western threat intelligence firms use. The actual entity is a specific unit inside Russian military intelligence, with a specific chain of command, specific aliases, and six specifically-named officers who got indicted by a US federal grand jury in October 2020.

Organisational Structure

Sandworm sits inside Russia's **Main Intelligence Directorate (GRU)**. Specifically, it's attributed to **Unit 74455**, formally the **Main Centre for Special Technologies (GTsST)**. The GRU hierarchy: GRU → Unit 55111 (Information Operations Troops / VI0) → two subordinate units:

- Unit 26165 / 85th Main Special Services Centre (GTsSS) → ****APT28**** (Fancy Bear)
- Unit 74455 / Main Centre for Special Technologies (GTsST) → ****APT44**** (Sandworm)

APT28 and APT44 sit under the same Information Operations Troops command and have collaborated on operations. Mandiant places APT44's formation at around **2009**, based on publicly available imagery of the unit's anniversary insignia.

The Alias Problem

Different threat intelligence vendors independently named the same group, producing a confusing alphabet soup that all refers to Unit 74455:

ALIAS	VENDOR	NOTE
Sandworm Team	iSight Partners	Original name, coined from Dune references in malware strings
APT44	Mandiant	Formal designation, April 2024
FROZENBARENTS	Mandiant	Alternative tracking designation
Seashell Blizzard	Microsoft	Current Microsoft designation
IRIDIUM	Microsoft	Legacy Microsoft designation
Voodoo Bear	CrowdStrike	CrowdStrike designation
IRON VIKING	SecureWorks	SecureWorks designation
ELECTRUM	Dragos	ICS-focused tracking by Dragos
TeleBots	ESET	ESET designation, particularly for 2016-2017 campaigns
Quedagh	F-Secure	F-Secure designation

The October 2020 Indictment

On October 19, 2020, a US federal grand jury indicted **six GRU Unit 74455 officers** for their roles in the operations documented in this report. The charges covered: 2015/2016 Ukraine electrical attacks, NotPetya, the 2017 French presidential campaign, Olympic Destroyer, the OPCW operation, and Georgia attacks in 2018/2019.

OFFICER	ROLE
Yuriy Andrienko	Developed components of NotPetya and Olympic Destroyer malware
Sergey Detistov	Developed NotPetya components; prepared spearphishing for 2018 Olympics
Pavel Frolov	Developed KillDisk and NotPetya components
Anatoliy Kovalev	Developed tools for French election and 2018 Olympics spearphishing
Artem Ochichenko	2018 Olympics spearphishing; technical recon of Georgia's Parliament
Petr Pliskin	Developed components of NotPetya and Olympic Destroyer

None of these officers will face trial. Russia doesn't extradite its intelligence officers. The indictment is, however, a formal legal record – with evidence attached, naming specific individuals inside the GRU responsible for the most destructive cyberattack in history. That matters for the historical record, even if not for the courtroom.

Attribution confidence: For APT44, multiple independent lines of evidence converge – formal government attribution across the US, UK, EU, Australia, Canada, and New Zealand; independent technical tracking by ESET, Mandiant, Microsoft, CrowdStrike, and Dragos; documentary evidence from the NTC Vulkan leak; and the October 2020 indictment naming specific individuals with specific charges. Attribution confidence is about as high as it gets in threat intelligence.

SECTION 03

Campaign Timeline

There's a temptation to treat NotPetya as a singular event. A bolt from the blue. That would be wrong. NotPetya was not a beginning – it was a destination. The end point of a years-long campaign of escalating capability and escalating ambition that began in the shadows of Russia's 2014 annexation of Crimea.

Origins: The BlackEnergy Years (2009-2014)

MITRE places Sandworm's formation at around 2009. In the early years, the group operated under the BlackEnergy banner – a modular malware framework supporting keylogging, network sniffing, credential harvesting, and lateral movement. The targeting was already taking shape: government bodies, energy infrastructure, defence organisations. The sectors that would define their campaigns for the next decade. Then Russia annexed Crimea in 2014, and everything accelerated.

First Blood: The 2015 Ukraine Power Grid Attack

December 23, 2015. In the Ivano-Frankivsk region, power company operators watched helplessly as their own control systems were used against them – breakers tripping remotely, substations going dark, their HMI inputs overridden by an invisible hand on the other side of the network. Around 230,000 people lost power for about six hours.

This was the first confirmed cyberattack to cause a real-world power outage. Initial access came through spearphishing emails with malicious Office attachments. Once inside, the group spent months mapping the infrastructure, harvesting credentials, and learning the ICS environment. On December 23rd, they pulled the trigger: remote commands to substation breakers, malicious firmware overwriting serial-to-ethernet gateways to prevent remote recovery, phone line DoS to block outage reports, UPS systems scheduled to shut down servers. Scorched earth. On the way out, the VBA macro deleted itself.

Encore: The 2016 Power Grid Attack

December 17, 2016. Exactly a year later. This time with Industroyer – purpose-built ICS malware that speaks industrial protocols natively (IEC 101, IEC 104, IEC 61850, OPC DA). Where BlackEnergy was a general framework adapted for ICS, Industroyer was designed from scratch to attack power grid equipment directly. This was a significant escalation. The platform was adaptable to any grid running similar protocols.

The Bridge: TeleBots and the Road to NotPetya (2016-2017)

While attacking the power grid, a parallel campaign was running – one ESET tracks as TeleBots – that would provide the direct evolutionary path to NotPetya.

- **December 2016, Wave 1:** Attacks against Ukrainian financial institutions using KillDisk. First wave: no encryption, no ransom, just file overwriting. Second wave added a 222 BTC ransom demand as camouflage – the actual goal was always damage.

- ****January–March 2017:**** TeleBots compromised a Ukrainian software company and used its VPN tunnels to pivot into several financial institutions. Primary tool: Python/TeleBot.A (Telegram Bot API backdoor), C2 at 130.185.250.171 , masquerading domain transfinance.com.ua .
- ****May 18, 2017 – XData:**** Win32/Filecoder.AESNI.C appeared right after M.E.Doc execution – with embedded Mimikatz, automatic LAN lateral movement, and PsExec propagation. Architecture almost identical to what NotPetya would use five weeks later. This was a dress rehearsal.

// Analytical Note Notice what happened between 2015 and 2017. Initial access went from spearphishing (human interaction required, limited scale) to supply chain compromise via M.E.Doc (zero user interaction, simultaneous infection of thousands). That's not accidental evolution – it's a deliberate tactical upgrade driven by the need for scale. You can't spearphish your way into thousands of networks in hours. You can if you control the update server for software every Ukrainian business is legally required to use.

The Main Event: NotPetya (June 27, 2017)

June 27, 2017. Ukraine's Constitution Day. The timing wasn't coincidental – a national holiday meant reduced IT staff capacity and slower response times. NotPetya detonated through M.E.Doc's compromised update server simultaneously into thousands of Ukrainian networks, then escaped outward through VPN connections to foreign partners. Full technical breakdown in Section 04. The campaign-level point: NotPetya was the convergence of everything Sandworm had built since 2015 – KillDisk philosophy, Mimikatz+PsExec from XData, M.E.Doc access, EternalBlue – assembled into a single weapon.

Wartime: The 2022 Campaign

February 24, 2022. Russia re-invaded Ukraine. Sandworm was ready. Mandiant documents six phases of what became the most sustained and sophisticated cyber campaign in documented history:

- 1** Espionage & Pre-Positioning 2019–Jan 2022. PARTYTICKET, NEARMISS, NEARTWIST pre-staged against government targets.
- 2** Initial Destructive Operations Feb–Apr 2022. CADDYWIPER, JUNKMAIL, Industroyer.V2 + SOLOSHRED + AWFULSHRED. Timed with military invasion.
- 3** Sustained Targeting May–Jul 2022. Multiple CADDYWIPER waves against Ukrainian government targets.
- 4** Maintaining Footholds Aug–Sep 2022. Consolidation – maintaining access for strategic advantage.
- 5** Renewed Disruptive Campaign Oct 2022–Jan 2023. CADDYWIPER against energy (coordinated with missile campaign); PRESSTEAL against telecoms; native MicroSCADA binary abused for OT LOTL.
- 6** Refocus on Espionage Feb–Dec 2023. NIKOWIPER deployments. Battlefield recon, drone manufacturer phishing, Infamous Chisel Android malware.

SECTION 04

NotPetya Deep Dive

June 27, 2017. Somewhere in a Maersk office, screens started going black. Not one. Not a few. All of them. Across 17 of the shipping giant's 76 terminals – Los Angeles, Rotterdam, Mumbai, Algeciras – gates went down, cranes froze, and tens of thousands of trucks were turned away from ports that had simply stopped working. Containers would remain lost in cargo yards across the world for three months. That was just one company. One of hundreds.

VICTIM	LOSS	IMPACT
Maersk	~\$300M	Shipping halted globally across 76 terminals, 17 directly affected
Merck	\$870M	Drug manufacturing halted – including flu vaccine production
FedEx / TNT	\$400M	Months to recover data; TNT operations severely degraded
Saint-Gobain	~\$400M	French construction giant – operations across 33 countries disrupted
Mondelez	\$188M	Cadbury's parent company – factories halted globally
Reckitt Benckiser	\$129M	Consumer goods disruption
TOTAL (US Gov.)	\$10B	White House estimate – most destructive cyberattack in history

What NotPetya Actually Was

NotPetya borrowed its MBR replacement code from Win32/Diskcoder.Petya – which is why every analyst initially called it a Petya variant. The critical difference: Diskcoder.C's authors modified the MBR code specifically so **recovery would be impossible**. The generated decryption key contains non-acceptable characters that literally cannot be typed into the ransom screen. There was never a path to recovery. The payment instructions were set dressing.

File encryption: AES-128 + RSA-2048. But with deliberate "mistakes" too consistent to be accidents: only the first 1MB of each file was encrypted; no header or footer written to encrypted files; files were not renamed; files larger than 1MB have no padding, making key verification impossible. Even with a valid key, you couldn't reliably identify which files were encrypted. **This wasn't sloppy coding. This was deliberate. Maximum damage, minimum recoverability.**

Three Spreading Vectors

Once inside a network, NotPetya used three simultaneous spreading mechanisms – this combination is what made it so catastrophically effective:

- ****EternalBlue + DoublePulsar**** – the NSA exploit leaked by Shadow Brokers. Key difference: NotPetya used EternalBlue only against machines within the local network, not the open internet. Designed for targeted network penetration, not global spray-and-pray.
- ****Mimikatz + PsExec**** – embedded Mimikatz DLL extracts Windows credentials from memory, then PsExec uses those credentials to execute the malware on every other reachable machine on the LAN. If domain admin credentials were cached anywhere – and in most enterprise environments they are – NotPetya owned the entire domain.
- ****WMI**** – a third lateral movement method running alongside the other two. Belt, suspenders, and a second belt.

The combination meant a single infected machine could compromise an entire domain regardless of whether individual machines were patched against EternalBlue. And why did

it spread outside Ukraine? Companies infected in other countries had **VPN connections to Ukrainian branches or business partners**. NotPetya tunnelled out through those connections. It wasn't designed to go global – it escaped.

The M.E.Doc Supply Chain: Patient Zero

M.E.Doc – Ukrainian accounting software legally required for government financial reporting – had a massive install base embedded in Ukrainian corporate infrastructure. And its update server had been compromised. ESET found the smoking gun: a PHP backdoor (`medoc_online.php`) deployed in M.E.Doc's FTP directory (`ftp://me-doc.com.ua/TESTUpdates/`). Password-protected, meaning whoever placed it had the password – persistent access to the update infrastructure, established months before June 27th.

The TeleBots VBS backdoor was also delivered via M.E.Doc – connecting the June 2017 attack directly to the January–March 2017 campaign. The C2 domain `bankstat.kiev[.]ua` had its DNS A-record flipped to `10.0.0.1` on the day of the outbreak – infrastructure burned on the way out the door.

// Analytical Note Did Sandworm underestimate the blast radius? Yes – and the evidence supports it. EternalBlue was implemented LAN-only. The M.E.Doc vector was aimed at Ukrainian accounting software users. These are the choices of an operator expecting contained destruction inside Ukrainian networks. The global collateral damage appears to have been a miscalculation. Sandworm built a weapon aimed at Ukraine and accidentally hit the world.

SECTION 05

TTPs & Malware Arsenal

Mandiant describes APT44's approach as **"low-equity" malware delivery**: prioritise open-source tools, commodity malware, and criminally-sourced capabilities over custom implants. When a tool gets burned, it's expendable. Leaked documents from **NTC Vulkan** confirmed APT44's parent unit contracted out framework development to private Russian companies. Criminal marketplaces are a regular sourcing channel.

The operational playbook runs through five phases:

- ****Living on the Edge:**** Initial access via compromised edge infrastructure – routers, VPN appliances, internet-facing servers.
- ****Living off the Land:**** Pre-existing tools inside the network: PowerShell, WMI, PsExec. Limits forensic footprint significantly.
- ****Going for the GPO:**** Creating persistent, privileged access. Get domain admin, control Group Policy, push anything to every machine simultaneously.
- ****Disrupt and Deny:**** Deploying pure wipers and destructive tools. The endgame.
- ****Telegraphing Success:**** Hacktivist personas on Telegram amplify the narrative of disruption, regardless of actual impact.

The Full Malware Arsenal

BlackEnergy Era (2009-2016)

BLACKENERGY	2009–2016	Modular framework – keylogger, network sniffer, KillDisk MBR corruption. The foundation of everything.
INDUSTROYER	2016	Purpose-built ICS attack platform. Speaks IEC 101, IEC 104, IEC 61850, OPC DA natively. Deployed in 2016 power grid attack.

NotPetya Era (2016–2017)

KillDisk / Win32/Filecoder.NKH	Dec 2016	File overwriter disguised as ransomware. AES-128 + RSA-1024. Linux variant: Python/Filecoder.R using RSA-2048 + AES-256.
XData / Win32/Filecoder.AESNI.C	May 18, 2017	NotPetya dress rehearsal. Embedded Mimikatz DLL, automatic LAN lateral movement, PsExec propagation. Appeared right after M.E.Doc execution.
ETERNALPETYA / NotPetya	Jun 27, 2017	Wiper masquerading as ransomware. EternalBlue + EternalRomance + Mimikatz + PsExec + WMI. \$10 billion in damage.
Python/TeleBot.A	Jan–Mar 2017	Python + Rust backdoor using Telegram Bot API for C2. Blocking it means blocking Telegram entirely.

Expansion Era (2018–2021)

VPNFILTER	2018	Multifunctional router malware targeting network infrastructure globally. Capable of rendering devices permanently unrecoverable.
Olympic Destroyer	2018	False-flag wiper deployed at PyeongChang Olympics. Attribution deception layers pointing at North Korea and China.
CYCLOPS BLINK	2019–2021	Router/firewall botnet malware. Successor to VPNFilter.

Wartime Arsenal (2022–2023)

PARTYTICKET	Feb 2022	Fake ransomware/wiper. Go-based. Strings hardcoded: /403forBiden/, /WhiteHouseE/, .encryptedJB extension. Political trolling baked into the binary.
CADDYWIPER	2022–ongoing	Pure wiper. Overwrites files, deletes backup catalogs, destroys shadow copies. Deployed repeatedly against government and energy targets.
INDUSTROYER.V2	Apr 2022	Upgraded ICS weapon targeting Ukraine's high-voltage substations. More capable than the 2016 original.
NEARMISS / NEARTWIST	2022	Disk wipers – NEARMISS targets FAT/NTFS structures at physical drive level; NEARTWIST uses Mersenne Twister PRNG.
GOGETTER	2022	Go-based tunneler using Yamux TLS C2 channel. Persisted via systemd. Used alongside Industroyer.V2.
Infamous Chisel	2023	Android malware. Harvests system info, commercial app data, and Ukrainian military-specific application data from captured devices.
SMOKELOADER / RADTHIEF	2023	Exploited WinRAR vulnerability to deliver SMOKELOADER dropper, loading RADTHIEF (Rhadamanthys Stealer) in-memory.
NIKOWIPER	2023	Wiper pair – MBR-targeting variant alongside standard file wiper, deployed in Phase VI espionage-focused campaign.

SECTION 06

Key Patterns

Destruction Is The Point, Not a Side Effect

The single most important pattern: when Sandworm wants to destroy something, they build tools specifically designed to ensure it cannot be recovered. KillDisk, NotPetya's unrecoverable encryption, CADDYWIPER, NIKOWIPER, NEARMISS – all pure wipers across every campaign era. When ransomware aesthetics appear, they're costumes.

Tactical Evolution Is Deliberate

Sandworm doesn't repeat itself. Each major campaign introduces a meaningful evolution. Spearphishing (2015) became supply chain compromise (2017). General malware adapted for ICS (2015) became purpose-built ICS weapons (2016), then OT-native LOTL (2022). This is an organisation that learns.

Supply Chain Is The Preferred Force Multiplier

The M.E.Doc compromise wasn't a one-off. Before NotPetya: compromised VPN tunnels through a software company. After: software developer access for downstream critical infrastructure. Ongoing: trojanised software installers via torrents. Sandworm prefers to compromise trust relationships rather than attack targets directly.

Ukraine Is The Laboratory, But The Mandate Is Global

Every major capability was developed and tested against Ukrainian targets first. But the mandate was never limited: French elections, PyeongChang Olympics, OPCW, Georgia. Mandiant frames APT44 as a flexible instrument of power. The capabilities refined against Ukraine are fully transferable.

Destruction and Influence Are Integrated

APT44's three pillars – KRIKS (espionage), ITV (technical attack), IPV (psychological influence) – are integrated components of a unified playbook. Hacktivist front personas on Telegram claim credit and amplify the narrative. In one documented case, the Telegram post came before the actual attack – an operator error revealing how tightly scripted the whole operation is.

Coordination With Conventional Military Activity

2022 wartime campaign makes this explicit: cyber operations timed with kinetic missile strikes on power infrastructure; wiper deployments coordinated with the invasion; espionage supporting battlefield reconnaissance. Cyber and kinetic as force multipliers for each other.

SECTION 07

Targeting Analysis

Energy Infrastructure

The most persistent target – 2015, 2016, and repeated throughout 2022. Not a target of opportunity: a strategic priority. Every major APT44 capability generation was validated against Ukrainian energy infrastructure.

Government Institutions

Targeted for both espionage and disruption across all campaign phases. Primary collection target in pre-war positioning; primary destruction target during wartime phases.

Western Democratic Processes

The 2016 US election, the 2017 French presidential campaign, and ongoing credential theft targeting mail servers globally. Strategic logic: degrade the legitimacy of Western democratic institutions, amplify internal divisions.

International Bodies and Investigators

OPCW (2018, targeted during the Novichok investigation); Bellingcat and investigative journalism entities (December 2023–January 2024). The pattern is retaliatory and suppressive.

Olympics: Retaliation as Targeting Logic

Russia was banned for state-sponsored doping. APT44 deployed Olympic Destroyer – disrupting the opening ceremony WiFi and official app – loaded with false flags pointing at North Korea and China. No intelligence value. Pure institutional payback.

Global Critical Infrastructure

The targeting pattern that should concern defenders globally: APT44 has demonstrated the ability to attack industrial control systems. IEC protocols Industroyer attacks are used in power grids worldwide. MicroSCADA operates in substations across Europe and beyond. **Future global ICS impact may not be accidental.**

// Analytical Note While the world focused on NotPetya's destruction, APT44 may have selectively harvested valuable data from the same compromised networks during the operation. The M.E.Doc supply chain gave simultaneous access to thousands of Ukrainian networks. In the window between infection and detonation, collection was possible – and consistent with APT44's documented approach of using non-selective initial access vectors to reach wide-ranging targets, then down-selecting victims of interest. The \$10 billion in damage was the visible part of the operation. The intelligence collection may have been the quiet part. Not confirmed – but analytically coherent.

SECTION 08

Assessment & Outlook

After documenting everything in this report, the conclusion almost writes itself. The evidence is overwhelming, the pattern is consistent, the trajectory is clear. But "overwhelming evidence" and "clear trajectory" are analyst-speak for something more

visceral: this group is not going away, they're getting better, and the world is not ready for what comes next.

What APT44 Actually Is

There's a framing problem in how most people think about Sandworm. The instinct is to categorise them – ransomware group, espionage unit, hacktivist collective – and then apply whatever mental model fits. None of those categories fit. APT44 is a **full-spectrum cyber operations unit** conducting espionage (KRIKS), technical attack (ITV), and psychological influence (IPV) as an integrated whole – the expression in cyberspace of Russia's "information confrontation" (IPb) doctrine, which treats information operations and military operations as inseparable.

The NTC Vulkan Problem

Leaked documents from Russian company **NTC Vulkan** detailed project requirements for a framework contracted by APT44's parent military unit. Mandiant also assesses that at least one additional unnamed Russian cybersecurity company provided direct operational support to APT44's Ukraine operations. This matters: sanctions and indictments targeting GRU officers don't fully address the capability pipeline – the private sector contractors keep working. Since 2022, APT44 has increased use of tools and bulletproof hosting from **criminal marketplaces** – the line between state-sponsored and cybercriminal blurring.

Where This Is Going

Ukraine remains the primary focus. As long as the war continues, APT44 will be tasked with supporting it. The wartime campaign is adapting – shifting from disruption to espionage as the conflict transitions to attrition – but it's not stopping.

The global threat is real and underappreciated. Sandworm has a history of electoral interference. Operations continue across North America, Europe, the Middle East, Central Asia, and Latin America. The OT attack capability is ready to be applied wherever Russian national interests dictate.

The information operations will mature. The hacktivist persona ecosystem is getting more sophisticated. The integration of attack and narrative amplification is getting tighter. As that discipline improves, the psychological impact of APT44 operations will increase even if the technical impact stays constant.

What deters APT44? That's an open question – and an uncomfortable one. A decade of operations suggests that cost imposition, technical attribution, and diplomatic protest have not significantly degraded their capability or willingness to use it. **Sandworm will keep operating. Keep evolving. The tools will change – they always do. The mission won't.**

SECTION 09

MITRE ATT&CK; Heatmap

This section maps APT44's documented techniques across the MITRE ATT&CK; Enterprise and ICS matrices. [NP] = appears specifically in NotPetya. [R] = recurring across three or more distinct campaigns – the most reliable APT44 signatures for detection and hunting.

INITIAL ACCESS			
T1566.001	[I] [R] [I]	Phishing: Spearphishing Attachment	Malicious Office macros – dominant 2015-2016, replaced by supply chain post-2017
T1195.002	[I] [N] [P] [I]	Supply Chain: Compromise Software Supply Chain	M.E.Doc update server compromise – defining NotPetya initial access technique
T1195		Supply Chain Compromise	Trojanised software installers on Ukrainian/Russian forums. Ongoing as of 2024
T1133	[I] [R] [I]	External Remote Services	Dropbear SSH with hardcoded backdoor password; VPN tunnel exploitation
T1078	[I] [R] [I]	Valid Accounts	Harvested credentials used across all major campaigns
T1190		Exploit Public-Facing Application	Edge infrastructure exploitation (routers, VPN appliances) – primary post-2017
EXECUTION			
T1059.001	[I] [R] [I]	PowerShell	In-memory credential harvesting (2016); TANKTRAP wiper deployment via GPO (2022)
T1059.005	[I] [R] [I]	Visual Basic	VBA macro chain (2015); VBScripts for SSH server; TeleBots VBS backdoor
T1047	[I] [N] [P] [I] [I] [R] [I]	Windows Management Instrumentation	Remote execution and system surveys (2016); wmic for NotPetya propagation
T1569.002	[I] [N] [P] [I]	System Services: Service Execution	Psexec for network propagation
T1218.011	[I] [N] [P] [I] [I] [R] [I]	System Binary Proxy Execution: Rundll32	NotPetya installs via rundll32.exe on remote systems
PERSISTENCE			
T1543.002		Systemd Service	GOGETTER persisted via systemd (2022)
T1543.003	[I] [R] [I]	Windows Service	Industroyer boot persistence; ImagePath registry replacement with backdoor binary
T1053.005	[I] [N] [P] [I] [I] [R] [I]	Scheduled Task	NotPetya reboot (1hr post-infection); SHARPIVORY dropper; CaddyWiper GPO execution
T1554		Compromise Host Software Binary	Trojanised Windows Notepad for Industroyer persistence (2016)
T1505.003		Web Shell	P.A.S. Webshell; Neo-REGEOORG on internet-facing server (2022)
T1136.002	[I] [R] [I]	Create Account: Domain Account	Privileged domain accounts (2015); "admin" and system accounts (2016)

CREDENTIAL ACCESS			
T1003.001	[[] [N] [P] [] [[] [R] []]	OS Credential Dumping: LSASS Memory	Plainpwd, Mimikatz, comsvcs.dll across TeleBots, XData, and NotPetya
T1003.003		OS Credential Dumping: NTDS	ntdsutil.exe for Active Directory database backup
T1056.001	[[] [R] []]	Input Capture: Keylogging	SetWindowsHookEx; BlackEnergy keylogger plugin (2015)
T1040	[[] [R] []]	Network Sniffing	intercepter-NG; BlackEnergy sniffer for LAN-to-ICS credential capture (2015)
DEFENSE EVASION			
T1036	[[] [N] [P] [] [[] [R] []]	Masquerading	Malicious installers as Windows updates; PsExec as dllhost.dat; executables as .txt files
T1027	[[] [R] []]	Obfuscated Files or Information	Base64, ROT13, AES, zlib compression; heavily obfuscated Industroyer Notepad backdoor
T1070.001	[[] [N] [P] []]	Indicator Removal: Clear Windows Event Logs	wevtutil used to clear all major Windows event logs
T1070.004	[[] [R] []]	Indicator Removal: File Deletion	Backdoor self-deletion post-payload drop; vba_macro.exe self-deletion (2015)
LATERAL MOVEMENT			
T1021.002	[[] [N] [P] []]	Remote Services: SMB/Windows Admin Shares	PsExec via ADMIN\$ share for remote command execution
T1570	[[] [R] []]	Lateral Tool Transfer	move command to network shares; GP0-distributed payloads; ISO transfer to OT network
T1484.001		Group Policy Modification	GP0s to deploy and execute malware (2022) – the "Going for the GP0" playbook
IMPACT			
T1485	[[] [R] []]	Data Destruction	CaddyWiper, SDelete, BlackEnergy KillDisk, JUNKMAIL null-byte overwrite
T1486	[[] [N] [P] []]	Data Encrypted for Impact	NotPetya file and MBR encryption with 2048-bit RSA (non-recoverable by design)
T1490	[[] [R] []]	Inhibit System Recovery	Backup catalog deletion; shadow copy destruction
T1210	[[] [N] [P] []]	Exploitation of Remote Services	EternalBlue + EternalRomance SMBv1 – dual exploit for maximum propagation
T1529	[[] [N] [P] [] [[] [R] []]	System Shutdown/Reboot	NotPetya scheduled reboot 1 hour post-infection
T1561.002	[[] [R] []]	Disk Wipe: Disk Structure Wipe	BlackEnergy KillDisk MBR corruption; NIKOWIPER.MBR

ICS Matrix (Selected)

T0855	[[[R] []	Unauthorized Command Message	Remote substation breaker commands via HMI (2015); MicroSCADA SCIL-API substation commands (2022)
T0831		Manipulation of Control	Live breaker opening via remote HMI causing blackouts (2015)
T0857	[[[R] []	System Firmware	Serial-to-ethernet gateway firmware overwrite to brick devices and deny control (2015)
T0894		System Binary Proxy Execution	MicroSCADA scilc.exe for SCADA instruction delivery – OT-native LOTL (2022)
T0828	[[[N] [P] [] [[[R] []	Loss of Productivity and Revenue	2015 power outage (~230,000 affected); NotPetya halted Merck vaccine manufacturing
T0814		Denial of Service	Phone line DoS during 2015 attack; serial-to-ethernet converter bricking
T0813		Denial of Control	KillDisk rendered remote recovery devices unusable (2015)
T0859	[[[R] []	Valid Accounts	VPN and dual-homed system lateral movement (2015, 2016)

High-Density Technique Clusters

Cluster 1 – Credential Harvest + Lateral Movement: T1003.001 (LSASS dump) → T1078 (valid accounts) → T1021.002 (SMB/Admin shares) + T1569.002 (PsExec) + T1047 (WMI). Appears in TeleBots 2017, XData, NotPetya, and 2022 wartime campaign. The most reliable APT44 lateral movement signature.

Cluster 2 – Wiper Deployment via GPO: T1078 (valid accounts) → T1484.001 (GPO modification) → T1053.005 (scheduled task) → T1485/T1561 (data destruction/disk wipe). The "Going for the GPO" playbook – APT44's preferred wiper deployment mechanism in the 2022 campaign.

Cluster 3 – Supply Chain + Mass Deployment: T1195.002 (software supply chain compromise) → T1195 (staged malicious installers) → T1078 (valid accounts from broad access) → destructive payload. The NotPetya delivery model, continued post-2017.

SECTION 10

IOC Reference

Important caveat: IOCs have a shelf life. Infrastructure gets rotated, file hashes get updated, domains expire. The indicators below are historically documented – useful for threat hunting in historical data and building detection rules. For current, live IOC feeds, refer to the Mandiant APT44 VirusTotal collection linked in references.

// TeleBots Jan–Mar 2017 Campaign

C2 IP	130.185.250.171	Primary C2 for Python/TeleBot.A
C2 Domain	transfinance.com.ua	Masquerading as financial sector traffic
Tor Relay	severalwdadwajunior	Hosted on same C2 IP

Tor Fingerprint	4513E6402D186DC2EC65E95394AE78821BE78D91	Tor relay fingerprint
Tor OR Address	130.185.250.171:1458	Onion router address
// TeleBots VBS Backdoor C2		
Domain	bankstat.kiev[.]ua	C2 domain
Note	A-record → 10.0.0.1	Flipped on June 27 2017 – infrastructure burn on NotPetya detonation day
// M.E.Doc Supply Chain Compromise		
PHP Backdoor	medoc_online.php	Deployed in M.E.Doc FTP directory
FTP Location	ftp://me-doc.com.ua/TESTUpdates/	Password-protected PHP backdoor location
Payload Host	putdrive.com	Used for C2 payload hosting
// NotPetya / Win32/Diskcoder.C		
Ransom Contact	wowsmith123456@posteo.net	Fake ransom contact – non-functional by design
Bitcoin Wallet	1Mz7153HMuxXTuR2R1t78mGSdzaAtNbBwX	Wallet in ransom screen
PsExec Dropped As	dllhost.dat	Masquerading as legitimate Windows process
Event Log Clearing	wevtutil cl Setup/System/Security/Application	Log clearing on exit
Reboot Trigger	Scheduled task – 1hr post-infection	Timed reboot to complete MBR overwrite
// KillDisk / Win32/Filecoder.NKH		
Bitcoin Wallet	1Q94RXqr5WzyNh9Jn3YLDGeBoJhxJBicF	Wave 2 ransom wallet
Ransom Contact	vuyrk568gou@lelantos.org	Ransom contact email
Ransom Amount	222 BTC (~\$250,000)	Camouflage, not intent
Extension Added	.xcrypted	Encrypted file extension
Ransom Note	!readme.txt	Ransom note filename
// VirusTotal IOC Collection		
Collection URL	virustotal.com/gui/collection/0bd93a520cae1fd917441e6e54ff263c88069ac5a7f8b9e55ef99cd961b6a1c7	Maintained and updated by Mandiant/Google. Requires registered VirusTotal account.

YARA Detection Rules

Mandiant published YARA hunting rules for the following APT44 malware families in the APT44 report appendix. Use for retrospective threat hunting and detection rule building:

- ****CADDYWIPER**** – M_APT_Wiper_CADDYWIPER_1: searches physical device call patterns and drive letter constants
- ****NEARTWIST**** – M_APT_Disrupt_NEARTWIST_1 / M_APT_Wiper_Win32_NEARTWIST_1: Mersenne Twister PRNG patterns, physical drive targeting strings
- ****NEARMISS**** – M_APT_Distupt_NEARMISS_1 / M_Hunting_Win32_NEARMISS_1/2: FAT/NTFS corruption code patterns
- ****PARTYTICKET**** – M_APT_Disrupt_PARTYTICKET_1/2: strings /403forBiden/, /WhiteHouse/, .encryptedJB extension

- ****GOGETTER**** – M_APT_Tunneler_GOGETTER_1/2/3: Go build ID patterns, hashicorp/yamux library strings
- ****DARKCRYSTALRAT**** – M_Backdoor_DARKCRYSTALRAT_1: C2 check-in and config string patterns
- ****SMOKELOADER**** – M_Downloader_SMOKELOADER_1: WinMain and memory allocation opcode patterns
- ****ITCHYSPARK**** – M_APT_Worm_Win32_ITCHYSPARK_1/2/3: WMI and SMB spreader component patterns
- ****ROARBAT**** – M_Disrupt_ROARBAT_1: takeown and del command strings
- ****SHARPIVORY**** – M_Hunting_Dropper_SHARPIVORY_Strings_1: WriteAllBytes, schtasks strings

References & Sources

- Greenberg, Andy. *Sandworm: A New Era of Cyberwar and the Hunt for the Kremlin's Most Dangerous Hackers*. Wired / Doubleday, 2019.
- ESET *WeLiveSecurity*. "TeleBots are back: Supply-chain attacks against Ukraine." June 30, 2017. welivesecurity.com
- MITRE ATT&CK.; "Sandworm Team (G0034)." attack.mitre.org/groups/G0034/
- MITRE ATT&CK.; "NotPetya (S0368)." attack.mitre.org/software/S0368/
- Mandiant / Google Cloud. "APT44: Unearthing Sandworm." April 17, 2024. [services.google.com](https://services.google.com/fh/files/doc/alerts/APT44.pdf)
- US Department of Justice. "Six Russian GRU Officers Charged in Connection with Worldwide Deployment of Destructive Malware." October 19, 2020.
- UK National Cyber Security Centre. *Advisory on Sandworm / APT44 operations*.

// GhostWire publishes original collection-based threat intelligence research. IOCs from this report should be treated as historical reference data. Independent verification recommended before operationalizing any indicator. All research conducted on publicly available information. No affiliations. No ads.

ghostwireintel.com // @GhostWireCTI // EARLY 2026